UNITÀ 1 · CYBERSECURITY · LEZIONE 4

Difensori: i cyberdefender

Chi difende un'azienda, con quali strumenti, e che cosa succede minuto per minuto quando scatta un allarme vero.

5G TPSI Ruoli, red e blue team, SOC, incident response, notifica NIS2

PER COMINCIARE

Se lavorassi nella sicurezza, quale ruolo sceglieresti?

SONDAGGIO

- **A** Analista in un SOC, a caccia di allarmi
- **B** Penetration tester, attaccante autorizzato
- **C** Analista forense, ricostruisce le prove
- **D** CISO, decide strategia e budget
- **E** Sviluppatore di software sicuro

IL PUNTO DI PARTENZA

Non "se", ma "quando"

> **Esistono solo due tipi di aziende: quelle che sono state attaccate e quelle che lo saranno.**

Robert Mueller, allora direttore dell'FBI, alla RSA Conference di San Francisco, 2012

Per questo una difesa seria non si limita a prevenire: deve **rilevare** presto e **rispondere** bene.

LE PROFESSIONI

Un'Europa di ruoli: il quadro ECSF

L'agenzia europea ENISA descrive 12 profili professionali della cybersecurity nell'**European Cybersecurity Skills Framework**.

- CISO
- Incident Responder
- Threat Intelligence Specialist
- Cybersecurity Architect
- Cybersecurity Auditor
- Cybersecurity Implementer
- Risk Manager
- Penetration Tester
- Digital Forensics Investigator
- Legal, Policy & Compliance Officer
- Cybersecurity Researcher
- Cybersecurity Educator

> Non solo tecnici: ci sono ruoli di **diritto**, di **gestione** e di **formazione**. E servono tutti.

ATTACCO E DIFESA, INSIEME

Red team, blue team, purple team

Red team

Simula un attaccante reale, **con autorizzazione scritta** e regole d'ingaggio. Cerca la strada che un criminale userebbe.

Blue team

Difende ogni giorno: monitora, rileva, risponde, migliora le configurazioni.

Purple team

Rosso e blu lavorano insieme: ogni tecnica provata diventa una regola di rilevamento.

Vicini al red team: il **penetration test**, più limitato e con un perimetro preciso, e i programmi di **bug bounty**, che pagano chi segnala vulnerabilità in modo responsabile.

PUZZLE

Abbina ogni ruolo al suo compito

Analista SOC di primo livello	---	Attacca, autorizzato, un perimetro concordato
Incident responder	---	Presenta i rischi alla direzione e chiede il budget
Analista forense	---	Esamina gli allarmi e scarta i falsi positivi
Threat hunter	---	Contiene l'attacco e coordina il ripristino
CISO	---	Cerca intrusi che nessun allarme ha segnalato
Penetration tester	---	Raccoglie e conserva le prove senza alterarle

IL CENTRO OPERATIVO

Come lavora un SOC

Fonti

Log di firewall, server, VPN, EDR, posta, cloud.

SIEM

Raccoglie, normalizza, correla gli eventi e genera allarmi.

Analisti L1, L2, L3

Smistamento, indagine, casi complessi e caccia.

SOAR

Automatizza i playbook: blocca un IP, isola un PC.

MTTD: tempo medio per rilevare un incidente.

MTTR: tempo medio per rispondere e risolvere.

QUIZ A TRABOCCHETTO

Che cos'è un falso negativo per un SOC?

QUIZ

- **A** Un allarme che scatta per un'attività innocua
- **B** Un allarme vero che l'analista chiude per sbaglio
- **C** Un attacco reale che non genera nessun allarme
- **D** Un allarme ripetuto due volte per lo stesso evento

AL COMPUTER · 30 minuti

Un mini-SIEM in Java

Salva il log a destra come **accessi.log** e il codice, dentro la classe con `SOGLIA = 3`, come **MiniSiem.java** nella stessa cartella. Esegui `java MiniSiem.java`.

```
Map<String,Integer> falliti = new LinkedHashMap<>();
for (String riga : Files.readAllLines(Path.of("accessi.log"))) {
  String[] c = riga.trim().split("\\s+"); // ora esito utente ip
  String esito = c[1], utente = c[2], ip = c[3];
  if (esito.equals("FAIL")) falliti.merge(ip, 1, Integer::sum);
  else {
    int n = falliti.getOrDefault(ip, 0);
    if (n >= SOGLIA) System.out.println("ALLARME ALTO  " + ip
        + ": " + n + " falliti, poi accesso come " + utente);
    falliti.remove(ip);
  }
}
falliti.forEach((ip, n) -> { if (n >= SOGLIA) System.out.println(
    "ALLARME MEDIO " + ip + ": " + n + " falliti, nessun accesso"); });
```

```
03:10:02 FAIL admin 203.0.113.7
03:10:03 FAIL admin 203.0.113.7
03:10:04 FAIL root 203.0.113.7
03:10:05 OK admin 203.0.113.7
08:01:10 FAIL lbianchi 198.51.100.20
08:01:25 OK lbianchi 198.51.100.20
09:15:00 FAIL test 192.0.2.44
09:15:01 FAIL test 192.0.2.44
09:15:02 FAIL guest 192.0.2.44
```

Controllo (SOGLIA = 3): due allarmi, ALTO per 203.0.113.7 e MEDIO per 192.0.2.44. Nessun allarme per chi ha sbagliato una volta.

UNA STORIA VERA

75 centesimi che hanno scoperto una spia

1986, Lawrence Berkeley Laboratory. L'astronomo **Clifford Stoll** deve spiegare un ammanco di **75 centesimi** nella contabilità del tempo macchina.

Scopre un utente sconosciuto, lo segue per mesi stampando i suoi comandi e lo attira con file falsi: era un hacker tedesco che rivendeva informazioni al KGB.

Lo racconta nel libro *The Cuckoo's Egg*, 1989.



QUANDO L'ALLARME È VERO

Le fasi della risposta a un incidente

1

Preparazione

Piano, ruoli, contatti, strumenti, esercitazioni.

2

Identificazione

È un incidente? Quanto è grave? Che cosa è coinvolto?

3

Contenimento

Fermare la diffusione: isolare, bloccare, cambiare password.

4

Eradicazione

Eliminare la causa: malware, account creati, falla.

5

Ripristino

Tornare operativi da sistemi puliti, sorvegliando.

6

Lezioni apprese

Che cosa cambiamo perché non succeda più?

PUZZLE

Phishing con password inserita: metti in ordine le azioni

1. Si aggiorna la formazione con l'esempio reale, senza colpevolizzare
2. Si reimposta la password, si chiudono le sessioni attive, si verifica la MFA
3. L'analista conferma: la pagina era falsa e la password è stata inserita
4. Si cercano nei log altri accessi con quell'account e chi ha ricevuto la stessa mail
5. Si cancellano le copie della mail da tutte le caselle e si blocca il dominio
6. Il dipendente segnala la mail al SOC con il pulsante apposito

AL COMPUTER · 20 minuti

Triage: sei allarmi, un solo analista

#	Allarme
1	Login dall'Italia alle 9:00 e dal Brasile alle 9:20, stesso utente, senza VPN
2	L'antivirus ha bloccato e messo in quarantena un allegato
3	Un PC esegue `vssadmin delete shadows` e rinomina 400 file al minuto
4	Il server di backup di notte invia 30 GB al cloud aziendale, come ogni giorno
5	Un account di servizio viene aggiunto al gruppo Domain Admins
6	Dieci password sbagliate dello stesso utente in cinque minuti, poi più nulla

Consegna e controllo: in **triage-cognome.ods** dai a ciascuno priorità (Critica, Alta, Media, Bassa) e prima azione. Il 3 è **Critica**; il 4 è un probabile falso positivo.

GLI OBBLIGHI DI LEGGE

Incidente significativo: l'orologio della NIS2

Entro 24 ore

Preallarme al CSIRT Italia: c'è un incidente, forse doloso, forse con effetti su altri paesi.

Entro 72 ore

Notifica con una prima valutazione: gravità, impatto, indicatori di compromissione.

Entro un mese

Relazione finale: causa, misure adottate, effetti.

> Le ore partono da quando il soggetto **viene a conoscenza** dell'incidente. Se ci sono dati personali c'è anche la notifica al **Garante** per il GDPR, entro 72 ore.

QUIZ

Lunedì alle 9 un soggetto NIS2 scopre un incidente significativo. Il preallarme va inviato...

QUIZ

- **A** entro 72 ore, come per il GDPR
- **B** entro martedì alle 9
- **C** entro un mese, con la relazione finale
- **D** solo se sono coinvolti dati personali

AL COMPUTER · 30 minuti · a squadre

Tabletop: ransomware alle 3 di notte

Siete il team di risposta di un'azienda di trasporti, soggetto NIS2 importante. Ogni 5 minuti il docente legge un nuovo evento. Assegnate i ruoli: coordinatore, tecnico, comunicazione, legale.

1. A ogni evento scrivete decisione, chi la prende e a che ora.
2. Preparate il testo del preallarme al CSIRT Italia, in 5 righe.
3. Consegnate **tabletop-squadra.md** con la cronologia.

30:00

Controllo: la prima decisione isola i sistemi; il preallarme parte prima di 24 ore; nessuno paga senza decisione della direzione; c'è una riga sulle lezioni apprese.

E DOPO IL DIPLOMA?

Come si diventa cyberdefender

- **Università**: informatica, ingegneria informatica, corsi magistrali in cybersecurity.
- **ITS Academy**: percorsi biennali post-diploma nel settore ICT, con molte ore in azienda.
- **Allenamento**: CTF, laboratori legali, la prossima lezione.
- **Certificazioni** professionali, quando hai già una base.



BIGLIETTO D'USCITA

Completa prima di uscire

Il sistema che raccoglie e correla i log e genera gli allarmi si chiama _____.

Un attacco reale che non genera nessun allarme è un falso _____.

La squadra che simula l'attaccante, con autorizzazione, è il _____.

Il preallarme NIS2 va inviato entro ____ ore al CSIRT Italia.

L'ultima fase della risposta a un incidente è quella delle lezioni _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- 12 profili ECSF: tecnici, gestionali, legali
- Red, blue e purple team; pentest e bug bounty
- SOC: fonti, SIEM, analisti, SOAR
- Falsi positivi e falsi negativi: un compromesso
- Sei fasi di risposta, fino alle lezioni apprese
- NIS2: 24 ore, 72 ore, un mese

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.